CELULAR AUTONOMA v2.2

ERCs, defenses, and a full-system security audit

Every public ERC/EIP that touches an autonomous cell:
adopt what helps - reject what hurts - prove the rest.

79 tests passing - issues #24-#27 - PR #28 (stacked) - AUDIT.md findings register

How the audit was run

- SCOPE: 14 production contracts - v2.0 core trio + Colony, v2.1 organ cast (7 + base), interfaces.
- METHOD: line-by-line manual review of every state-changing function - authority, CEI ordering, value-flow, revert-mode.
- ADVERSARY LENS: stranger EOA - botched graft - MALICIOUS grafted organ - dishonest keeper - hostile colony owner - failing yield venue.
- INVARIANTS FIRST: 7 system invariants written down (I1-I7 in AUDIT.md), each mapped to its enforcement point.
- EVIDENCE: every finding gets an executable regression (test/v2.2-audit.test.js A1-A11) - findings that cannot be tested are marked as such.
- RESULT: 18 findings - 11 fixed in code, 4 documented-accepted, 3 recommendations; 0 unresolved Highs.

Adopted: standards the cell now speaks

ERC-165

interface detection

The Nucleus registry REFUSES a WORKER graft that can't declare IWorker; the Membrane refuses a shield that can't speak screen(). Graft-time proof replaces runtime guessing.

ERC-4626

yield vaults

The Mitochondrion speaks the standard vault interface (deposit/withdraw/preview/max*). Aave, Morpho, LST wrappers become drop-in respiratory substrates - no bespoke venue surface to trust.

ERC-8004

trustless agents

Membrane carries the discovery fields the (Jan-2026 mainnet-live) agent registries point at: agentName, registrationURI. Cells show up on the agents' menu without building any registry.

Bonus behavior: EIP-6780 verified - apoptosis never relied on selfdestruct. EIP-150 63/64 rule priced into the keeper gas budget since v2.1.

Defended against: what public ERCs would do to us

ERC-20 as food	REJECTED. Fee-on-transfer breaks the per-payer ledger; rebasing breaks cost-basis math (the 4626-on-rebasing-asset incident class); honeypots weaponize approvals. The larder is native ETH only - there is deliberately no token deposit path. Token yield enters ONLY through a 4626 venue.
ERC-721 / 1155	ABSENT BY DESIGN. onERC721Received/onERC1155Received are reentrancy doors; the audit verified zero token-callback implementations in the system. Future NFT organs must gate callbacks.
4626 inflation attack	DEFENDED. First-depositor donation-skew steals later deposits unless countered; our standard-compliant mock carries OZ-style virtual shares AND virtual assets - regression A11 proves: attacker donates 10 ETH, recovers ~0.01; victim loses <1%.
Approval tokens	N/A SAFE. The cell never places ERC-20 approvals - there is no allowance surface to abuse; a compromised organ can only move the cycle budget it was granted.

Account abstraction: the autonomy end-game (aligned, not yet wired)

- EIP-7702 (live since Pectra, May 2025): an EOA-shaped cell handle that runs real contract code at the same address.
- ERC-4337 EntryPoint v0.9 (Nov 2025): bundlers submit the cell's intent; PAYMASTERS spend the cell's own food for gas - keepers need no wallet at all, the ultimate self-funding statement.
- ERC-7562 canonical validation rules: exactly the discipline our act()/spend() windows already enforce locally (no unbounded state growth in validation paths).
- ERC-7579 / ERC-6900 modular accounts: our WORKER + graftTemplate design IS a module system - mapping organs onto 7579 module registers is a thin adapter, proof the design generalizes.
- Audit warning shipped with the plan: a 7702 delegation target is a NEW TRUST ROOT - it must be colony/DAO-governed, never keeper-settable.
- EIP-712 + ERC-1271: required the moment we accept signed agent intents (8004 registries themselves mandate both) - flagged in AUDIT.md roadmap.

Why not wired in this PR: it needs an L2 deployment target + EntryPoint dependency - next iteration, on Base Sepolia.

Audit findings I: the three Highs (all fixed, all regression-proven)

A1	Silent organs graftable	BUG: registry accepted any WORKER - the cycle would try act() on modules structurally unable to answer	FIX: ERC-165 gate at _register: WORKER must DECLARE IWorker (try/catch probe for clean rejects) [regression A1]
A3	Clone-init race	BUG: organelle clones were first-caller-wins: an attacker could pre-bind a clone to a rogue nucleus before the curator's graft installed it	FIX: initialize() is COLONY-only; graftTemplate does clone+bind+register atomically; no path around [regression A3]
A4	Cycle gas DoS	BUG: an organ's act() had no gas bound - one malignant graft could burn the whole block every single express()	FIX: act{gas: workerGasStipend} + frame-atomic try/catch; default 2M sized to legit worst job [regression A4]

Audit findings II: the bounded-growth family (M/L)

A5/ A6	Registry size was unbounded -> every cycle's scans grew with it	cap 24 aux organs; tombstone accounting honest (evict frees slot, re-graft re-spends it)
A7	Golgi packages array grew forever; full scan every cycle	64 live-package cap + swap-and-pop pruning (length == live count)
A8	Peroxisome flagged list unbounded; scan per detoxification	32-flag cap; saturation DROPS FLAGS, never reverts a permissionless report()
A9	Ribosome order queue unbounded	32-pending cap
A10	Keeper aging list grew per distinct keeper	cap 512; past it, credits stay payable FOREVER (fails safe toward keepers, never seizes)

Accepted-risk notes (B2-B7) + recommendations (Ownable2Step, slither/forge fuzz pass, adapter audit) live in AUDIT.md §2/§6.

Three lessons the audit earned

1. CAPS MUST FAIL TOWARD THE USER.

The keeper-list cap chose: past 512 entries, forfeiture STOPS (credits stay payable forever) - the bounded version can only do less harm, never more. A cap that silently forfeited newcomers would be a fund-loss bug wearing a gas-fix costume.

2. ROUNDING IS AN ORACLE.

v2.2's first 4626 draft reduced cost basis proportional to shares redeemed - which silently RE-DERIVED phantom yield after every harvest and would have over-withdrawn funds belonging to other depositors. The shipped invariant (yield == staked - principal, exact in asset space) is simpler AND provable. Native-ETH vaults must also price shares BEFORE counting the inflow (B1) - preview vs deposit now match.

3. BOUNDS INTERACT - TUNE THEM TOGETHER.

Worst-case cycle gas is now aux-cap x stipend (24 x 2M = ~48M): shrink one knob below the other's needs and an organ quietly becomes OrganFailed forever. The docs pair them; the deck pairs them; the monitor should too.

Results & the honest ledger

79	18	11	0
tests passing	audit findings	fixed in code	open Highs

Still accepted risk (documented, not fixed):

- B2: harvest recipient is owner-set full-gas ETH - malicious only if the owner attacks itself; pull-payments listed as the hardening path.
- B3: administer = owner config power over a cell's own organs - consistent with the owner's pre-existing full capital authority; governance organ is the replacement.
- B4: digest-vs-claim race is TTL-gated (30d default) - raise TTL where keepers are slow.

Next: Ownable2Step, slither + forge-invariant fuzz campaign, ERC-4337/7702 spike on Base Sepolia, then the first REAL venue adapter (audited as its own component).